Vzor, před podpisem ke kontrole. CodeKom s.r.o.

B) Smlouva o zpracování osobních údajů

Obec je správcem a CodeKom s.r.o. zpracovatelem podle čl. 28 GDPR. Smlouva je přílohou 3 smlouvy A a ve věcech osobních údajů má před ní přednost.

Správce: Obec [NÁZEV OBCE], IČO [IČO OBCE], [ADRESA OBCE]

Zpracovatel: CodeKom s.r.o., IČO [IČO], [SÍDLO]

Článek 1. Předmět a pokyny

1. Zpracovatel zpracovává osobní údaje jen pro správce a jen v rozsahu potřebném k poskytování služby podle smlouvy A.
2. Pokyny správce jsou tato smlouva, nastavení služby provedené obcí a písemné pokyny zaslané datovou schránkou nebo e-mailem.
3. Povaha a účel zpracování, druhy údajů a kategorie subjektů jsou v příloze B1. Zpracování trvá po dobu smlouvy A a do výmazu podle článku 5.
4. Pokud by podle zpracovatele pokyn porušoval právní předpisy, upozorní na to správce bez zbytečného odkladu.

Článek 2. Povinnosti zpracovatele

1. Každá osoba s přístupem k údajům je vázána mlčenlivostí, která trvá i po skončení její práce.
2. Zpracovatel zavádí technická a organizační opatření podle čl. 32 GDPR uvedená v příloze B3 a pravidelně je testuje.
3. Zpracovatel pomáhá správci:
    1. s žádostmi subjektů údajů: žádost doručenou jemu přepošle správci do 5 pracovních dnů a v administraci poskytuje nástroje pro export a výmaz,
    2. se zabezpečením, ohlašováním porušení, posouzením vlivu a předchozí konzultací podle čl. 32 až 36 GDPR.
4. Porušení zabezpečení oznámí správci bez zbytečného odkladu, nejpozději do 24 hodin od zjištění. Oznámení obsahuje údaje podle čl. 33 odst. 3 GDPR a zpracovatel ho průběžně doplňuje.
5. Vede záznamy o činnostech zpracování podle čl. 30 odst. 2 GDPR.
6. Zpřístupní správci informace potřebné k doložení povinností a umožní audit jednou ročně s oznámením 30 dní předem, po incidentu kdykoli. Náklady auditu nese správce, ledaže audit zjistí podstatné porušení.
7. Nepoužívá osobní údaje ani dokumenty obce pro vlastní účely, neprodává je a netrénuje na nich obecné modely umělé inteligence.

8. Data ukládá v EU. Do třetích zemí je předává jen podle kapitoly V GDPR a jen podzpracovatelům z přílohy B2.

Článek 3. Podzpracovatelé

1. Správce dává obecné povolení k zapojení podzpracovatelů z přílohy B2.
2. Přidání nebo výměnu podzpracovatele oznámí zpracovatel nejméně 30 dní předem e-mailem a v administraci.
3. Správce může do 30 dní vznést odůvodněnou námitku. Nedohodnou-li se strany, může obec smlouvu A vypovědět bez sankce a s vrácením poměrné části ceny.
4. Zpracovatel uloží podzpracovatelům stejné povinnosti jako má sám a za jejich plnění odpovídá správci.

Článek 4. Povinnosti správce

1. Správce odpovídá za právní základ zpracování, za informování subjektů údajů (dokument C) a za jmenování pověřence.
2. Před zveřejněním dokumentu na úřední desce nebo webu znepřístupní osobní údaje, které zveřejnit nesmí.
3. Do služby nevkládá zvláštní kategorie údajů podle čl. 9 GDPR ani rodná čísla, pokud to příloha B1 výslovně nepředpokládá.

Článek 5. Ukončení

1. Po skončení smlouvy A zpracovatel umožní správci export dat po dobu 30 dní.
2. Poté data vymaže do 60 dní, ze záloh do 90 dní, ledaže jejich uložení vyžaduje právní předpis. Výmaz správci písemně potvrdí.

Článek 6. Odpovědnost

1. Odpovědnost vůči subjektům údajů se řídí čl. 82 GDPR.
2. Rozsah náhrady mezi stranami se řídí článkem 8 smlouvy A.

Příloha B1. Přehled zpracování

Povaha zpracování: uložení, zobrazení, zveřejnění na pokyn obce, zasílání oznámení, zálohování a výmaz.

Činnost	Subjekty údajů	Osobní údaje	Doba uložení
Web a úřední deska	osoby uvedené v dokumentech obce, návštěvníci webu	údaje ve zveřejněných dokumentech, IP adresy v technických záznamech	dokumenty podle spisového plánu obce, technické záznamy 90 dní

Činnost	Subjekty údajů	Osobní údaje	Doba uložení
Formuláře a hlášení závad	občané	jméno, e-mail, telefon, text, fotografie, poloha	podle pokynu obce, výchozí 2 roky od vyřízení
Oznámení a krizová hlášení	uživatelé aplikace	identifikátor zařízení pro notifikace, zvolené části obce	do odhlášení odběru
AI asistent	uživatelé webu a aplikace	text dotazu bez vazby na účet	[30] dní, poté jen anonymní statistiky
Správa budov	zaměstnanci obce, nájemci prostor, držitelé čipů	jméno, identifikátor čipu, budova, čas odemčení	[12] měsíců
Administrace	zaměstnanci a zastupitelé obce	jméno, e-mail, role, záznamy o přihlášení a změnách	po dobu účtu, záznamy 12 měsíců
Kontakty zastupitelů	zastupitelé	jméno, funkce, služební kontakt, fotografie	po dobu funkce

Příloha B2. Podzpracovatelé

Podzpracovatel	Co dělá	Kde jsou data	Předání mimo EU
Supabase Pte. Ltd., Singapur	databáze, přihlašování, soubory	region AWS Frankfurt	technická podpora mimo EU na základě standardních smluvních doložek
Vercel Inc., USA	provoz webu a aplikace	[region Frankfurt, ověřit]	[ověřit: Data Privacy Framework nebo standardní smluvní doložky]
[POSKYTOVATEL SERVERU], ČR	server s AI asistentem	ČR	ne
Google (Firebase Cloud Messaging), Apple (Push Notification service)	doručení notifikací do telefonu	[ověřit]	[ověřit]
[EMAILOVÁ SLUŽBA]	odesílání e-mailů	[EU]	[ověřit]

Podzpracovatel	Co dělá	Kde jsou data	Předání mimo EU
[SMS BRÁNA], ČR	odesílání SMS	ČR	ne

Příloha B3. Technická a organizační opatření

- **Šifrování:** přenos přes TLS 1.2 a novější, šifrované úložiště a zálohy.
- **Přístupy:** role správce a redaktora, nejmenší nutná oprávnění, dvoufázové přihlášení pro správce, zámek účtu po 5 neúspěšných pokusech.
- **Oddělení obcí:** data každé obce jsou oddělená na úrovni databáze a přístup hlídá databáze, ne jen aplikace.
- **Zálohy:** denně, uchování 30 dní, zkouška obnovy jednou za čtvrtletí.
- **Záznamy:** historie verzí obsahu s autorem a časem změny, záznamy o přihlášení 12 měsíců.
- **Úřední deska:** každá změna dokumentu se ukládá jako verze a databáze nedovolí smazat dokument, který už visel.
- **AI asistent:** běží na serveru v ČR, dotazy se neposílají třetím stranám, neukládají se k účtu a nepoužívají se k tréninku.
- **Vývoj:** kontrola kódu, automatické testy, pravidelné aktualizace, testovací prostředí bez skutečných dat.
- **Incidenty:** psaný postup, bezpečnostní kontakt [E-MAIL], oznámení správci do 24 hodin.
- **Lidé:** závazek mlčenlivosti a školení jednou ročně.

Ke kontrole advokátem:

- předávání do třetích zemí u Vercelu a služeb pro notifikace
- lhůta 24 hodin pro oznámení porušení a postup při námitce proti podzpracovateli
- rozdělení rizika pokut mezi obcí a zpracovatelem
- zda obec nepotřebuje posouzení vlivu (DPIA) pro AI asistenta a polohu v hlášeních závad